

ГОДИШЕН ОБЗОР НА КИБЕРСИГУРНОСТТА

Киберзаплахи

Какво се променя, как атакуващите стигат до нас и какво можем да направим

2026 · Първо издание

Заедно за по-сигурна дигитална България



За този доклад

Този доклад е написан за хора, които трябва да вземат решения в реална среда — с ограничено време, ограничени ресурси и много информация. Ако управлявате организация, поддържате инфраструктура, разработвате софтуер или просто използвате дигитални услуги всеки ден, тук ще намерите обща картина и конкретни следващи стъпки.

Автор: **Николай Папазов**
Дата: Септември 2026
Лиценз: CC BY-NC-SA 4.0

Материалът е аналитичен обзор, изграден върху публични доклади и изследвания. Той се предоставя с образователна цел и не замества специализирана оценка на риска, правна консултация или план за реакция при конкретен инцидент.

Съдържание

Раздел	Какво ще намерите
Предговор	За кого е докладът и как да го използвате
Резюме	Най-важните тенденции и изводи на едно място
1. Икономика на инцидентите	Цена, последствия, сектори и инвестиции
2. Изкуствен интелект	ИИ като ускорител и рискът от сенчест ИИ
3. Заплахи	Мотиви, глобални събития, FIMI и държавно-свързана активност
4. Престъпна среда	Киберпрестъпност, онлайн измами и сексуална експлоатация на деца
5. Тактики, техники и процедури	Как започват атаките и как се развиват
6. Препоръки	Стратегически, технически и ежедневни мерки
Заключение	Какво означава всичко това за следващото решение

Нямате нужда да четете всичко наведнъж. Ако сте ръководител, започнете с резюмето, икономиката на инцидентите и стратегическите препоръки. Ако поддържате инфраструктура, преминете към тенденциите при атаките и техническите препоръки. Ако искате практични правила за ежедневната работа, отворете „Съвети за добра кибер хигиена“.



Предговор

Предговор

Щом сте отворили този доклад, вероятно вече знаете, че киберсигурността не е тема, която може да бъде оставена само на IT отдела. Въпросът е какво точно се променя и кое заслужава внимание първо.

Информация има много. Трудното е да я съберем в картина, която има смисъл за конкретната организация: какво може да бъде засегнато, през коя врата може да влезе атакуващият и какво ще направим, ако той успее. Големите международни доклади дават ценни данни, но често са дълги, технически и разпръснати между различни теми.

Този доклад е опит да събере най-важното на едно място. Не претендира да замени работата на организациите и изследователите, които стоят зад източниците. Напротив — стъпва върху нея и я поставя в по-практичен контекст.

Ще срещнете проценти, термини и конкретни техники. Но целта не е да запомните всички тях. Целта е да можете да отговорите по-добре на няколко прости въпроса: знаем ли какво притежаваме; знаем ли кой има достъп; виждаме ли навреме необичайното; и можем ли да действаме без да импровизираме?

Благодаря ви, че отделяте време за темата. Ако след последната страница виждате риска малко по-ясно и предприемете поне една конкретна стъпка, докладът си е свършил работата.





Методология

Методология

Този документ не е самостоятелно емпирично изследване. Той е аналитична компилация и синтез на множество независими източници, чрез които се изгражда обща картина на актуалната среда на киберзаплахите.

Основата са годишни и тематични доклади на ENISA, Europol, CERT-EU, CrowdStrike, Mandiant, IBM и IBM X-Force, Verizon, Cisco Talos, Palo Alto Networks Unit 42 и Европейската служба за външна дейност. Използвани са и допълнителни професионални, журналистиюни, научни и технически материали, които помагат за контекста и интерпретацията.

Информацията е сравнена и групирана по теми, вместо източниците да бъдат преразказани един след друг. Важно е да се има предвид, че отделните организации използват различни методологии, набори от данни, географски обхват и дефиниции. Затова процентите невинаги са директно сравними.

Целта не е да се създаде една „перфектна“ статистика. Целта е да се открояят тенденциите, които се повтарят достатъчно често, за да имат практическо значение. Когато в текста е използван израз като „в разглежданите данни“, той обозначава именно тази събрана извадка, а не универсална мярка за всички организации.





Резюме

Резюме

Най-важната промяна през 2025 г. не е появата на напълно нов тип атаки. Повечето успешни атаки продължават да започват от добре познати проблеми: незакърпени системи, откраднати идентификационни данни, прекомерни права, неправилни конфигурации, социално инженерство и експлоатация на доверето между системи и организации. Новото е скоростта, мащабът и ефективността, с които тези слабости се експлоатират.

За вас това означава нещо практично: процес, който работи добре „до утре“, вече може да работи твърде бавно. Средното eCrime breakout време намалява от 98 минути през 2021 г. до 29 минути през 2025 г. При най-бързите 25% от разглежданите пробиви извличането на данни се случва за под 72 минути, а новоразкрити уязвимости могат да започнат да се експлоатират за по-малко от 15 минути след публичното им оповестяване.

Цената на пробива също е голяма. В събраните за доклада данни средният глобален разход достига 4,99 млн. долара. Сумата обаче не показва всичко: инцидентът може едновременно да засегне поверителността, целостта и наличността на данните, да спре работа, да създаде регулаторни задължения и да увреди доверието. 58% от организациите в разглежданите данни все още не са се възстановили напълно.

Периметърът се размива. Облакът, SaaS платформите, API интерфейсите, CI/CD процесите, външните доставчици, OAuth интеграциите и машинните идентичности са част от средата, която трябва да бъде защитена. В анализ на 680 000 облачни идентичности 99% от потребителите, ролите и услугите са имали повече права, отколкото реално са им необходими.





Резюме

Затова идентичността все по-често е истинският периметър. Атакуващият предпочита да изглежда като нормален потребител: използва валиден акаунт, токен, браузърна сесия, OAuth разрешение или легитимен инструмент за отдалечен достъп. Защитата трябва да разпознава не само „лошия файл“, а и лошото поведение, което на пръв поглед изглежда нормално.

Изкуственият интелект ускорява тази промяна. Той прави фишинга, вишинга, deepfake сценариите и измамите по-убедителни и по-лесни за мащабиране. Но не отменя основните правила: нападателят пак се нуждае от достъп, идентичност, уязвимост или грешна конфигурация. Отделно организациите създават риск чрез сенчест ИИ — неодобрени услуги, към които служители изпращат код, документи, логове или клиентски данни.

Веригата на доставки е поредната повърхност за атака. За пет години се наблюдава близо четирикратно увеличение на сериозните пробиви, свързани с доставчици или трети страни. Един компрометиран доставчик, CI/CD процес, токен или SaaS услуга може да отвори вратата към много организации едновременно.

Рансъмуерът се адаптира. Криптирането вече не е задължителният финален ход; кражбата на данни, публичният натиск и заплахата за репутацията могат да свършат същата работа. Добър backup остава необходим, но не решава проблема, когато данните вече са напуснали организацията.

Резюме

Изводът е прост: устойчивата киберсигурност не идва от един продукт, като например антивирусен софтуер. Тя идва от постоянната способност да имате оглед над, това което притежавате, кой има достъп, къде са слабостите и какво се случва в момента. Това включва приоритизирано закърпване, устойчиво на фишинг мулти-факторно удостоверяване, минимални права, управление на човешки и машинни идентичности, контрол над OAuth и API достъпа, защита на доставчиците и CI/CD, управление на ИИ, обединена телеметрия, редовно тестване и предварително упражнена реакция.

Показател	Наблюдение	Какво означава за защитата
Средно eCrime breakout време	98 мин. (2021) → 29 мин. (2025)	Решенията и реакцията не могат да чакат следващия работен ден.
Среден глобален разход при пробив	4,99 млн. долара	Рискът е финансов, оперативен, регулаторен и репутационен.
Облачни идентичности с излишни права	99% в анализ на 680 000 идентичности	Проверявайте реалната необходимост от всяко право.
Сериозни пробиви по веригата на доставки	Почти 4 пъти повече за 5 години	Рискът на доставчика става част от вашия риск.
Пълно възстановяване след пробив	58% не са се възстановили напълно	Възстановяването включва доверие, регулации и промени, не само системи.
Извличане при най-бързите 25% пробиви	Под 72 минути	Ограничаването на достъпа и данните трябва да е подготвено предварително.



1. Икономика на инцидентите

1. Икономика на инцидентите

Инцидентът рядко приключва, когато атакуващият бъде отстранен. След техническото овладяване остават възстановяването на засегнатите системи, разследването, прекъснатите процеси, уведомяването на засегнатите страни, регулаторните задължения, загубеното доверие и инвестициите, нужни за да не се повтори същият сценарий.

Затова реалната цена не е само фактурата или размерът на заплатеният откуп. Тя е комбинация от време, данни, прекъсване на работа, репутация и бъдещи разходи. При съвременните атаки не се атакува само инфраструктурата — атакува се способността на организацията да продължи да съществува.

1.1. Колко струва един пробив

В разглежданите данни средният глобален разход при пробив на данни достига 4,99 млн. долара. По години стойностите са 4,35 млн. долара през 2022 г., 4,45 млн. през 2023 г., 4,88 млн. през 2024 г., 4,44 млн. през 2025 г. и 4,99 млн. в последната отчетена стойност. Стойността не трябва да се чете като цена на всеки отделен инцидент, а като ориентир за мащаба на риска в събраната извадка.

Колкото по-късно бъде открит инцидентът, толкова повече време има атакуващият да се движи, да събира данни и да подготвя следващия етап. При пълно възстановяване не става дума само за работеща инфраструктура. Включени са нормализирани операции, изпълнени регулаторни задължения, възстановено доверие и предприемане на мерки срещу повторение.

При рансъмуер натискът често се измерва и в откуп. Данните на Unit 42 показват спад на средния платен откуп като дял от приходите, но медианната стойност на плащането се увеличава от 1,25 млн. долара през 2024 г. до 1,5 млн. долара през 2025 г. В 68% от случаите, в които атакуващите са дали обещание, то е било изпълнено — важен сигнал, че плащането само по себе си не е надежден план за възстановяване.



1. Икономика на инцидентите

1.2. Какво се компрометира

Поверителността на данните е засегната в 82% от разглежданите инциденти, целостта им — в 64%, а наличността — в 53%. Дяловете се припокриват: един инцидент може едновременно да изведе информация, да я промени и да спре системите, които я използват.

Категория данни	Дял от инцидентите
Лична информация на потребители	52%
Лична информация на служители	35%
Друга непублична информация за потребители	34%
Интелектуална собственост	32%
Други категории	24%

53% от организациите в разглежданите данни не са криптирали чувствителните си данни в покой или при пренос по време на инцидента. Това не отменя останалите последствия, но криптирането може да намали обема на откраднатите данни и регулаторния риск.

Атаките рядко остават на една повърхност: 87% включват две или повече повърхности, 67% — поне три, а 43% — четири или повече. Относно скоростт на атаките - най-бързите 25% от пробивите извличането на данни започва за под 72 минути след първоначалното компрометиране; средното време до извличане за пълната извадка е два дни.

1. Икономика на инцидентите

1.3. Къде се намира рискът

Компрометираните данни са разпределени между локална инфраструктура, частен облак и публичен облак. В разглежданата извадка 30% са локални, 20% са в частен облак, 23% са в публичен облак, а 27% се намират в комбинация от трите. Това е още една причина инвентаризацията да включва не само сървърите, но и SaaS услугите, интеграциите, API ключовете и резервните копия.



1. Икономика на инцидентите

1.4. Сектори

Няма сектор извън обхвата на киберзаплахите. Различава се не толкова наличието на риск, колкото това какво може да бъде превърнато в лост за натиск: данни, пари, време, непрекъсваемост, интелектуална собственост, доверие или достъп до други организации.

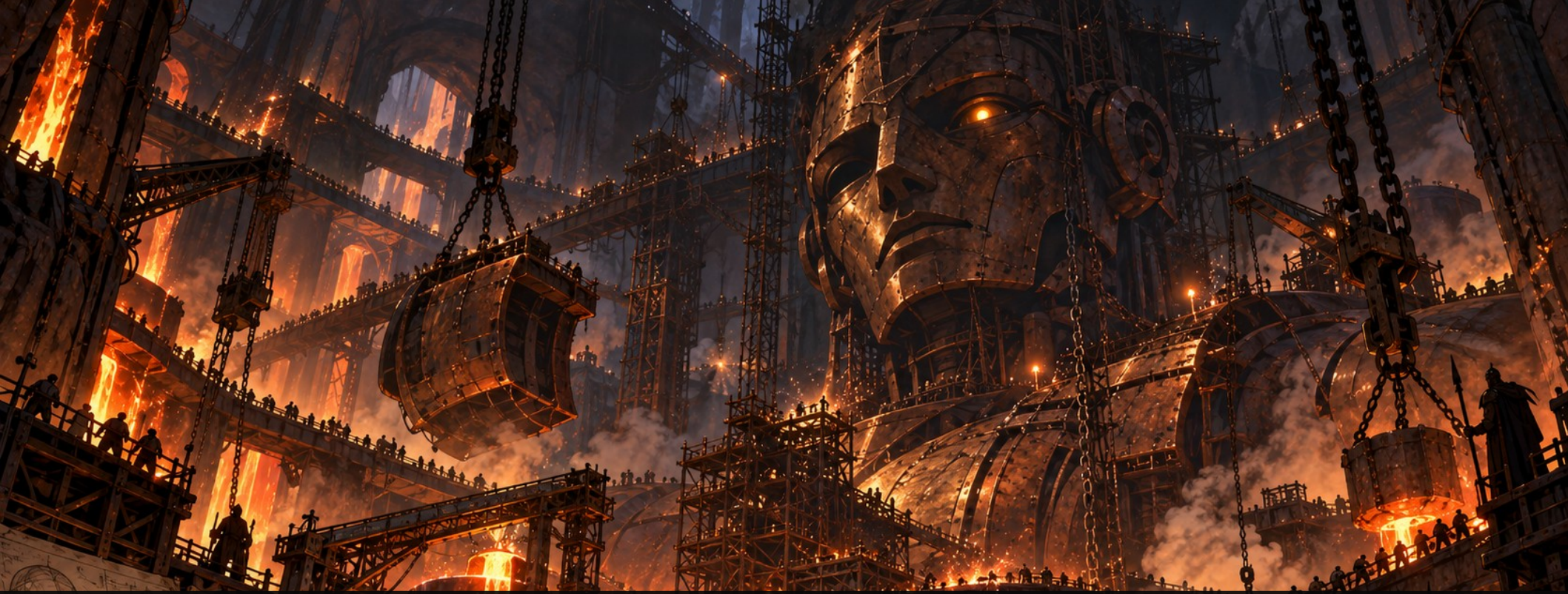
Сектор	Характерни атаки	Защо е привлекателна цел ?
Държавна администрация	DDoS, подмяна на съдържание на уебсайтове, кибершпионаж	Висока публичност, геополитическа значимост и зависимост на обществото от предоставяните услуги
Производство и промишленост	Рансъмуер, атаки срещу OT/ICS	Спирането на производството води до преки загуби и засилва натиска за бързо плащане на откуп
Здравеопазване	Рансъмуер, кражба на медицински данни	Критични услуги, при които дори кратко прекъсване може да има тежки последици
Финанси и банки	BEC, банкови троянски коне	Достъп до финансови средства, платежни процеси и чувствителни данни за транзакции
Доставчици на IT, облачни и управлявани услуги (MSP)	Атаки по веригата на доставки	Компрометирането на един доставчик може да осигури достъп до множество клиенти
Образование	Фишинг, рансъмуер, кражба на интелектуална собственост	Голям брой потребители, разклонени мрежи и ценна изследователска информация

1. Икономика на инцидентите

Сектор	Характерни атаки	Защо е привлекателна цел ?
Търговия и електронна търговия	Кражба на платежни данни, DDoS	Големи обеми клиентски и платежни данни и силна зависимост от онлайн услугите
Енергетика и критична инфраструктура	APT операции, саботаж, рансъмуер	Възможност за едновременно въздействие върху цифровите системи, икономиката и физическата среда
Транспорт и логистика	Рансъмуер, нарушаване на оперативната координация	Прекъсвания с широк икономически ефект, които засягат множество хора и организации и привличат обществено внимание
Медии и телекомуникации	DDoS, подмяна на съдържание на уебсайтове, шпионаж	Контрол върху комуникационни канали и достъп до широка аудитория

1.5. Инвестиции след инцидент

Повече от 64% от организациите посочват, че ще увеличат инвестициите си в сигурността след пробив. Най-често това означава наемане на специалисти (45%), планове за реакция и тестване (43%), IAM (41%), технологии за откриване и реакция като SIEM, SOAR и EDR (34%), инструменти за управление на ИИ (34%), управлявани услуги (33%), управление на криптографията (33%), обучение (31%), квантова сигурност (31%), DLP (30%) и офанзивно тестване (26%).



2. Изкуствен интелект

2. Изкуствен интелект

Изкуственият интелект вече е част от ежедневната работа в киберсигурността. Той обработва информация и участва в работни процеси чрез API, облачни услуги и други инструменти. Същите възможности използват и атакуващите.

ИИ намалява цената на убедителното съдържание, ускорява подготовката на атаки и сваля бариерата за хора с по-малко опит. Но той не отменя класическите входове: незакърпена система, откраднат акаунт, грешна конфигурация или човек, който може да бъде убеден да направи нещо. ИИ прави познатите слабости по-бързи и по-мащабни.

2.1. ИИ като ускорител

Генеративните модели могат да създават персонализиран фишинг, да клонират гласове, да създават deepfake съдържание и сценарии за вишинг. Съобщението вече може да бъде написано на естествен език, да е съобразено с длъжността и ролята на конкретния човек и да се маскира зад актуално събитие или работния му контекст. Това премахва част от традиционните сигнали за измама — лош превод, странен тон и очевиден шаблон.

Технологията работи в две посоки. По-неопитни участници могат да автоматизират задачи, които преди са изисквали повече знания. Напреднали групи могат да комбинират ИИ със съществуващи данни, инфраструктура и оперативен опит. Затова защитата не трябва да разчита само на това да „познае ИИ“. По-важни са идентичността, контролът на достъпа, телеметрията и бързата реакция.





2. Изкуствен интелект

2.2. Сенчест ИИ

Най-непосредственият риск понякога започва с нормален служител, който просто се опитва да свърши работата си по-бързо. В разглежданите данни 67% от потребителите не използват служебен акаунт на служебното си устройство при достъп до AI платформи. Когато неодобрена услуга обработва фирмена информация извън установения контрол, говорим за сенчест ИИ.

В един prompt може да попадне програмен код, клиентска информация, договор, лог или вътрешен документ. От гледна точка на служителя това може да не изглежда като „изпращане на данни“ — просто текст в разговор. От гледна точка на организацията данните вече са излезли към услуга, чийто достъп, задържане и последваща употреба не са ясни.

Пълната забрана не решава проблема, ако просто измести употребата към лични акаунти и неуправлявани услуги. По-устойчивият подход е да знаете какви AI услуги се използват, какви данни могат да достигат до тях и какви действия имат право да изпълняват. Колкото повече автономност получава един AI агент, толкова по-важни стават минималните права, логването, наблюдението и ясните граници за движението на данните.

Не можете да защитите това, което не знаете, че притежавате. В ерата на ИИ тази стара идея трябва да включва и моделите, агентите, API връзките и автоматизираните действия.



3. Заплахи



3. Заплахи

Киберзаплахата няма едно лице. Зад една атака може да стои организирана престъпна група, хактивисти, държавно-свързана структура, вътрешен човек или комбинация от участници, които използват една и съща инфраструктура. Различните противници имат различни цели, но все по-често използват сходни подходи: експлоатация на уязвимости, компрометирани идентичности, социално инженерство, експлоатация на трети страни и доверени връзки между системи.

CERT-EU отчита поне 174 отделни групировки създаващи опасност за киберсигурността, наблюдавани срещу институции и организации в ЕС през 2025 г. В тяхната извадка кибершпионажът и предварителното установяване на достъп представляват 38% от активността, а киберпрестъпността — 30%. ENISA използва различен период и методология, при които хактивизмът заема голям дял от регистрираните инциденти, основно чрез DDoS. Най-шумната заплаха обаче невинаги е най-разрушителната.

3. Заплахи

3.1. Мотиви на атакуващите

Мотив	Какво търси атакуващият ?	Типични прояви
Финансов	Финансова печалба чрез откуп или продажба на данни и достъп	Рансъмуер, измами, BEC, кражба на данни и криптовалута
Идеологически или политически	Публичност, изразяване на протест и смущаване на дейността със символичен ефект	DDoS, подмяна на съдържание на уебсайтове, кампании около значими събития
Геополитически	Шпионаж, предварително осигуряване на достъп за бъдещи операции и саботаж	APT операции, продължително присъствие в системите и разрушителни действия
Личен или вътрешен	Отмъщение, стремеж към престиж, личен конфликт или злоупотреба с предоставени права	Изтичане на информация, саботаж и злоупотреба с разрешен достъп

Мотивите невинаги могат да бъдат разграничени ясно. Инструменти на киберпрестъпници се използват и в държавно-свързани операции, а хактивистки групи могат да служат за прикритие. Инфраструктура, портфейли и инструменти се споделят или препродават. Затова атрибуцията изисква анализ на целите, контекста и поведението, а не само на използваната техника.



3. Заплахи

3.2. Глобални събития като катализатор

Кибератаките често следват дневния ред на обществото. Избори, международни срещи, конфликти и санкции дават убедителен повод за фишинг съобщения и увеличават публичния ефект от DDoS атаки. Атакуващите използват теми, които вече привличат вниманието на потенциалните жертви.

CERT-EU анализира 44 събития, свързани със злонамерена активност през 2025 г. Сред тях са международни срещи и конференции (30%), избори (18%), конфликти (9%), санкции (2%) и други събития (41%). Практическият извод за организациите е да предвиждат повишен киберриск в периоди на засилено обществено внимание.

3.3. Чуждестранно манипулиране на информация и намеса

Не всяка операция цели достъп до система. Понякога целта е достъп до вниманието на хората. Foreign Information Manipulation and Interference (FIMI) включва координирано и манипулативно поведение, което може да повлияе на обществени ценности, преценка, процеси и политически системи.

В разглеждания материал почти една четвърт от FIMI съдържанието е насочено към негативно представяне на ЕС. В 72,5% от разглежданите случаи срещу институции и обществеността на ЕС се използват актуално събитие или новина. Типичните механизми са неавтентични новинарски материали, изфабрикувани разследвания, истински цитати и изображения използвани извън контекст, фалшиви документи, координирано разпространение на информация и съдържание, генерирано или преработено с ИИ.

3. Заплахи

Тук границата между киберсигурност и информационна сигурност постепенно изчезва. Компрометиран профил може да публикува подвеждаща информация. Откраднат документ може да бъде променен преди публикуване. Истински данни могат да бъдат смесени с неавтентично съдържание. Защитата означава не само да пазим информацията, но и да можем да потвърдим нейния произход и контекст.

3.4. Тенденции при атаките

Атакуващите стават едновременно по-бързи и по-търпеливи. Криминалните групировки се стремят как най-бързо да достигнат от начален достъп до печалба, докато при кибершпионажът се търси възможно най-дълго незабелязано присъствие. Според Mandiant медианното време преди откриване достига 14 дни през 2025 г., спрямо 11 дни в предходния период; при наблюдавани случаи на кибершпионаж и операции със севернокорейски IT работници медианата достига 122 дни.

Паралелно eCrime breakout времето пада до 29 минути. Това е интервалът между първоначалния достъп и придвижването на атакуващия към друга система в мрежата. Облачните услуги са все по-критична цел, а активността срещу тях нараства с 37% в разглежданите данни. Идентичностите и интернет-достъпните периферни системи са особено привлекателни: могат да осигурят достъп, който изглежда легитимен, а наблюдението върху тях често е недостатъчно. Атакуващият търси слабите места в защитата и пътищата, които остават извън полезрението на организацията.

3.5. Държавно-свързани заплахи

Тук „държавно-свързани“ означава активност, която използваните източници атрибутират към държавно-подкрепяни или държавно-свързани участници. Това не е характеристика на държавите като общества или на техните граждани. Атрибуцията се изгражда на база на инфраструктура, инструменти, поведение, цели, разузнавателна информация и исторически модели и може да бъде актуализирана при нови данни.





Русия

Наблюдаваната активност свързана с Русия остава свързана с войната в Украйна и по-широкия геополитически контекст. Експлоатират се стари, незакърпени уязвимости, особено в мрежови устройства, за шпионаж и продължително събиране на информация. Паралелно се наблюдават разрушителни операции и по-опортюнистични атаки срещу OT и критична инфраструктура от предполагаеми про-руски хактивистки групи. Тихият шпионаж и шумният DDoS са различни модели, дори когато се появяват около едни и същи събития.

Китай

China-linked активността се характеризира с експлоатация на уязвимости, атаки по веригата за доставки и установяване на устойчив достъп. Cisco Talos отчита близо 75% увеличение на свързаните с Китай разследвания спрямо 2024 г. Комбинацията между нови уязвимости и отдавна известни слабости поставя фокус върху edge системите, които са публични, привилегировани и често по-слабо наблюдавани.





Северна Корея

Операциите свързани със Северна Корея комбинират социално инженерство, фалшиви професионални възможности, вътрешен достъп и финансово мотивирани действия. Кампании като Contagious Interview използват фалшиви рекрутъри и технически задачи, за да подтикнат жертвите да изпълнят код, да дадат идентификационни данни или да инсталират зловреден пакет. Така външният нападател може да придобие достъп, който обичайно принадлежи на служител или доверен партньор.

Иран

Активността, свързана с Иран, съчетава видими атаки за смущаване на дейността с операции за продължителен и прикрит достъп. Наблюдават се DDoS, подмяна на съдържание на уебсайтове, кражба на идентификационни данни, специално разработени задни вратички, LOLBins и разрушителен зловреден софтуер. ShroudedSnooper е посочен като пример за прикрита активност, насочена към телекомуникационни организации.

Разликите между тези групи са реални, но от гледна точка на защитника има общо ядро: уязвимости, идентичности, доверени отношения, социално инженерство, неуправлявани edge системи и недостатъчна видимост. Разликата е в това колко търпеливо и целенасочено могат да бъдат използвани.





4. Престъпна среда

4. Престъпна среда

Киберпрестъпността отдавна не е история за един човек, който сам намира жертва, пише инструмента си и извършва атаката от начало до край. Тя все повече прилича на икономика: достъп се продава, инфраструктура се наема, зловреден софтуер се предлага като услуга, а данни и услуги се обменят между различни участници.

Това намалява бариерата за навлизане. Престъпникът не трябва да може сам да разработва зловреден софтуер, да поддържа командни сървъри и да изпира печалбата си. Част от способностите могат да бъдат купени. Действията на правоохранителните органи разрушават инфраструктура и пазари, но престъпната екосистема се прегрупира: след закриването на една услуга се появява друга, а участниците преминават към нови платформи.

4.1. Средата на киберпрестъпниците

Initial Access Brokers (IAB) продават самия вход — компрометиран VPN акаунт, административни идентификационни данни или вече установен достъп до корпоративна среда. Друг участник може да купи този вход и да извърши следващата фаза, например кражба на данни или рансъмуер. Така атаката се превръща във верига от услуги.

Форумите и затворените общности служат за реклама, набиране, изграждане на репутация и преместване след затваряне на предишна платформа. Доверието се изгражда чрез история на транзакциите, препоръки, покани и vetting. Последователното използване на няколко VPN връзки, Tor и прокси сървъри с IP адреси на домашни потребители усложняват проследяването, а криптовалутите улесняват трансграничните плащания, макар че блокчейн транзакциите не са непременно анонимни.





4. Престъпна среда

Това е неприятно устойчив пазар. Когато има купувачи за достъп, зловреден софтуер и откраднати данни, ще има и продавачи. Затова защитата и правоприлагането трябва да ограничават не само инструментите, но и условията, които правят този пазар печеливш.

4.2. Онлайн сексуална експлоатация на деца

Тук терминологията има значение. Не става дума за „неподходящо съдържание“, а за деца, които са сексуално експлоатирани, и за престъпници и мрежи, които създават, разпространяват и продават материали от това насилие. Материалите с детско сексуално насилие (CSAM) съдържат реална жертва и реално престъпление. Когато се копират и препубликуват, злоупотребата продължава.

Сексуалното изнудване използва страх, срам и чувство за безизходица, за да държи детето в подчинение. Изпълняването на искането не гарантира, че изнудването ще спре. Натискът може да продължи с нови изисквания. Затворени общности, E2EE приложения, криптовалути и анонимни профили са инструменти за комуникация и прикриване, но не променят същността: извършва се насилие над деца.

В разглеждания материал се описват и live-distance child abuse операции, при които сексуалното насилие се поръчва дистанционно. Отбелязва се и нарастващ проблем с генерирани от ИИ материали, които затрудняват анализа и идентифицирането на реалните жертви. Технологията е инструментът; престъплението е експлоатацията.

4. Престъпна среда

При съмнение за сексуална експлоатация на дете навременната помощ е решаваща. Материалът посочва HELP4U като интерактивен ресурс за деца и жертви на сексуална експлоатация. В реална ситуация потърсете компетентните органи и подходящите служби за подкрепа. Детето не носи вина за това, че е било измамено, манипулирано или принудено.

4.3. Онлайн измами

Онлайн измамите са сред най-бързо растящите форми на организирана киберпрестъпност. Причината е проста: не е нужно да бъде пробита сложна инфраструктура, ако жертвата може да бъде убедена сама да изпрати парите, да даде данните си за вход или да одобри операция в полза на измамника.

Основните модели включват инвестиционни измами, компрометиране на бизнес имейли (Business Email Compromise), измами срещу платежни системи, фишинг, SIM инфраструктура и зловредно рекламиране. При BEC съобщението може да изглежда като реална комуникация от директор, доставчик или счетоводител работещ в същата фирма като жертвата. Тук уязвимостта е доверието.

Генеративният ИИ улеснява персонализирането на измамите, но не променя основния им механизъм. Измамникът използва познат контекст и създава усещане за спешност, за да подтикне жертвата сама да извърши привидно легитимна операция. Така действието може да остане незабелязано от техническите средства за защита. Нужни са независим канал за потвърждение, ясни правила за плащанията и работна среда, в която служителят може да спре съмнителна операция и да потърси съдействие.





5. Тактики, техники и процедури

5. Тактики, техники и процедури

Първоначалният достъп може да бъде получен по различни начини, но след него много атаки следват сходна последователност. Атакуващият се стреми да запази достъпа си, да събере идентификационни данни, да получи повече права и да премине към други системи. Крайната цел е да достигне ценната информация или процесите, от които организацията зависи.

Затова отделните техники не трябва да се разглеждат изолирано. Компрометиран акаунт може да бъде начален вектор и по-късно да служи за странично движение. Експлоатирана уязвимост може да отвори първата врата, а след това атакуващият да използва легитимни административни инструменти. Социалното инженерство може да даде достъп, който технически изглежда напълно валиден.

5.1. Начален вектор

Материалът групира основните начални вектори така:

1. Експлоатация на уязвимости.
2. Социално инженерство.
3. Откраднати идентификационни данни.
4. Предварително компрометиране.
5. Уеб компрометиране.
6. Зловреден софтуер.
7. Вътрешни заплахи.





5. Тактики, техники и процедури

Този списък показва защо периметърът не е само firewall или интернет-достъпна инфраструктура. Ако атакуващият има валидни credentials, той може да премине през нормалната автентикация. Ако компрометира доверен доставчик, достъпът може да дойде през съществуваща интеграция. Ако убеди служител да извърши действието, защитата може да види просто легитимен човек, който използва легитимна функция.

5.2. Социално инженерство

Социалното инженерство използва човешкото доверие и поведението на хората, за да преодолее защитните мерки. Според материала фишингът присъства в 40% от случаите, разследвани от Talos IR. Примамките все по-малко приличат на очевиден спам и все повече на ежедневна бизнес и IT комуникация.

Вишингът и т.нар. Интерактивни пробиви растат, а атакуващият използва валиден акаунт, нормален браузър, разрешен инструмент за отдалечен достъп или легитимна административна функция. Затова проверката трябва да обхваща и целта на действието: легитимен инструмент може да се използва за злонамерена операция.

5.3. Експлоатация на уязвимости

Експлоатацията на уязвимости е сред най-честите начини за начален достъп. Почти 40% от най-таргетираните уязвимости засягат end-of-life устройства, а 56% от новооткритите уязвимости в разглежданите данни не изискват автентикация. IBM X-Force отчита 44% увеличение в експлоатацията на публично достъпни приложения.

5. Тактики, техники и процедури

Старото не означава неактуално. В списъка с най-експлоатирани уязвимости се срещат CVE от 2025 г., PHPUnit от 2017 г., Adobe ColdFusion от 2013 г. и Log4Shell от 2021 г. Наследена инфраструктура, стари зависимости и непълна инвентаризация оставят дългосрочни слепи петна. 23% от разглежданите CVE-та засягат VPN, NGFW, load balancer-и, рутери и други мрежови устройства, а 25% засягат софтуерни рамки за разработка и библиотеки.

Материалът отчита 42% увеличение на 0-day уязвимостите, експлоатирани преди публичното разкриване. Новоразкрита уязвимост може да започне да се използва за под 15 минути. Следователно управлението на уязвимостите трябва да се основава на реалното излагане и активната експлоатация, не само на CVSS оценката.

5.4. Атаки по веригата за доставки

Най-ефективният начин да оцелиш с един коршум, многоого зайци (организации) понякога е да компрометираш нещо, на което всички те имат доверие. Веригите за доставки вече включват не само библиотеки, а и SaaS услуги, API интеграции, OAuth приложения, CI/CD платформи и автоматизирани процеси.

GitHub Actions, GitLab CI и други среди могат да бъдат цел за кражба на токени, API ключове и данни за удостоверяване в облачни услуги. Компрометиран токен може да даде продължителен достъп до хранилища и облачни среди. Когато доставчик съобщи за пробив, клиентът трябва веднага да знае: използваме ли услугата, до какви данни е имала достъп, кои токени трябва да се отнемат и какво е било изпълнено през интеграцията.





5. Тактики, техники и процедури

5.5. Рансъмуер

При рансъмуер криптирането е един от начините за натиск. В разглежданите случаи то присъства в 78%, кражбата на данни в 57%, а тормозът и сплашването в 10%. В 41% от атаките има заплаха за репутацията. Наред с искането за плащане срещу възстановяване на файловете все по-важен става и натискът чрез заплаха за публикуване на откраднатите данни.

Около 41% от жертвите успяват да възстановят системите си от бекъп без да платят откуп, но това не премахва downtime или изтичането на информация. В 26% от случаите атакуващите засягат и самите резервни копия. Резервните копия помагат да възстановим системите. При съвременния рансъмуер обаче трябва да установим и какви данни вече са изнесени от организацията.

5.6. Автентикация и идентичност

Идентичността е ключов фактор в почти 89% от разглежданите инциденти. Когато атакуващият може да се представи като легитимен потребител, много защитни механизми не трябва да бъдат заобикаляни. Валидните идентификационни данни, OAuth токените и API ключовете могат да осигурят достъп, без да е необходимо използване на софтуерна уязвимост.

Проблемът не засяга само хората. Служебните акаунти за автоматизирани услуги, приложенията и автоматизираните процеси често имат дълготрайни идентификационни данни и прекомерни права. При фрагментирано управление на идентичността, въпросът „кой е този потребител?“ вече не е достатъчен. Трябва да знаем как е удостоверен, какво може да прави, от какво устройство, чрез коя връзка между системите и дали това поведение е нормално.

5. Тактики, техники и процедури

5.7. DDoS

DDoS атаките са стара техника с нов мащаб. Материалът отчита 198% увеличение на обема в bits per second и 156% увеличение в packets per second при DDoS атака. Половината от наблюдаваните атаки продължават не повече от девет минути. Това ги прави кратки, силни и много видими — подходящи за хактивизъм и атаки около публични събития.

При публичната администрация 96,2% от разглежданите атаки са DDoS и често се появяват около събития с висока публичност. Кратката продължителност или ограничената техническа сложност не изключват значим обществен и оперативен ефект.

5.8. Ескалиране на привилегии

Първоначалният достъп рядко дава всичко, което е необходимо. Следващата задача е да се получат повече права чрез широки роли, остатъчни разрешения, повторно използвани данни за вход, токени, OAuth и прекомерно привилегировани нечовешки идентичности.

Сред наблюдаваните техники са Valid Accounts (T1078), OS Credential Dumping (T1003), извличане на данни от паметта на LSASS (T1003.001), NTDS (T1003.003) и Exploitation for Privilege Escalation (T1068). Използват се и идентификационни данни, съхранени във файлове и браузъри, brute force атаки и кражба на бисквитки за уеб сесии. В някои случаи излишните права на един административен акаунт осигуряват достъп, за който иначе би била необходима експлоатация на уязвимост.





5.9. Браузър и легитимни инструменти

Браузърът е работната среда, през която се използват SaaS приложения, облачни услуги, имейл, административни панели и системи за идентичност. Дейност, свързана с браузъра, присъства в 48% от разглежданите разследвания. ClickFix, SEO poisoning, spoofed sites, AiTM, infostealers и кражбата на сесийни бисквитки се вписват в по-широката тенденция към компрометиране на сесии и идентичности.

При Living-off-the-Land атакуващият използва налични легитимни инструменти за злонамерени цели. Платформите за отдалечено наблюдение и управление (RMM) и за управление на мобилни устройства (MDM) могат да бъдат използвани за изпълнение на команди, разгръщане на софтуер и промени в конфигурацията. Един и същ инструмент може да бъде и полезен, и злоупотребен. Контекстът определя разликата.

Когато разгледаме техниките заедно, картината е ясна: атакуващият търси лесен вход, след това се опитва да се слее с нормалната дейност, да вземе повече права, да премине към други системи и да достигне до данните или процесите, които са ценни. Защитата трябва да вижда същата свързана среда.

6. Препоръки

Голяма част от разгледаните инциденти започват с познат проблем, който е останал нерешен: незакърпена интернет-достъпна система, прекомерни права, преизползване на пароли, неуправлявана OAuth интеграция, доставчик с прекалено широк достъп, липсваща телеметрия или неодобрена AI услуга. Точно затова препоръките са практични и подредени около това, което организацията може да промени.

6.1. Стратегически препоръки

Преминете от реактивна към проактивна сигурност

Определете критичните системи, административните права и достъпа на доставчиците преди инцидент. Поддържайте актуална информация за уязвимостите и промените в средата и следете поведението, което може да създаде риск.





6. Препоръки

Управлявайте повърхността за атака

Инвентаризирайте интернет-достъпните системи, облака, приложенията, външните услуги, сенчестото IT и AI инструментите. Приоритизирайте това, което атакуващият може реално да достигне и използва — не само това, което има най-висока оценка за техническа тежест.

Третирайте идентичността като критична инфраструктура

Централизирайте управлението на човешки и машинни идентичности. Правата трябва да имат жизнен цикъл и да се премахват, веднага щом отпадне основанието за тях. Достъпът трябва да съществува, защото е необходим в момента, не защото някога е бил необходим.

Прилагайте минимални привилегии навсякъде

Пинципа на минималните привилегии трябва да обхваща служители, акаунти на услуги, приложения, API интеграции, CI/CD процеси, AI агенти и автоматизации. Компрометиран процес с минимални права създава проблем; компрометиран процес с административен достъп до половината организация създава доста голям проблем.

6. Препоръки

Подгответе се за пробив

Предварително определете как се прекратяват сесии, отнемат токени, изолират системи, блокират интеграции и комуникира инцидентът. Процедурите за аварийно предоставяне на достъп (break-glass) трябва да са известни и упражнени. Проверявайте плана за реакция с практически сценарии, за да знаете дали екипът може да го изпълни под напрежение.

Управлявайте риска от доставчици като собствен риск

Ако доставчик има достъп до данни, системи или процеси, той е част от вашия периметър. Ограничете достъпа, записвайте действията, за да можете да отговорите на въпросите: “Какво е извършено ?“, “Кога ?” и “От кого ?”.

Вкарайте сигурността в разработката

Интегрирайте проверки в CI/CD и DevOps процесите. Зависимости, код, конфигурации, токени и AI компоненти трябва да се проверяват преди внедряване в работната среда. Проверките за сигурност трябва да са част от процеса на разработка, за да се прилагат навреме и последователно.

Управлявайте ИИ като част от работната среда

Знайте какви AI системи използвате, какви данни достигат до тях, какви модели и инструменти могат да извикват и какви действия им е позволено да изпълняват. Управлението е по-устойчиво от забраната, когато технологията вече е част от ежедневната работа.





6. Препоръки

6.2. Технически препоръки

- **Приоритизирайте edge системите.** Проверявайте и закърпвайте VPN, firewall, мрежови устройства, платформи за виртуализация и друга интернет-достъпна инфраструктура.

- **Използвайте устойюиво на фишинг мулти-факторно удостоверяване.** Започнете от административни акаунти, VPN, облачни услуги и критични системи.

- **Централизирайте управлението на идентичностите.** Включете акаунти на услуги, API ключове, идентичности на приложения, OAuth приложения, токени, неактивни акаунти и RBAC права.

- **Управлявайте ключовете и данните за удостоверяване.** Не оставяйте ключове и идентификационни данни във файлове, конфигурации или процесите за автоматизирано изграждане на софтуер без контрол, ротация и наблюдение.

- **Ограничете OAuth и API достъпа.** Предоставяйте само необходимите права, записвайте използването, ротирайте ключовете и отнемайте неизползваните разрешения.

6. Препоръки

- **Анализирайте телеметрията в общ контекст.** Съпоставяйте сигналите от крайните устройства, идентичностите, облака, мрежата, електронната поща и приложенията, за да проследявате атаката като свързана последователност от действия.
- **Сегментирайте мрежата.** Потребителско устройство не трябва автоматично да дава път към работната среда, резервните копия или административна инфраструктура.
- **Защитете данните, не само системите.** Използвайте криптиране, класификация, DLP, одитни записи и контрол върху движението на чувствителна информация.
- **Наблюдавайте браузъра и каналите за комуникация.** Следете за необичайно поведение, свързано с ClickFix, подправени сайтове, фишинг и кражба на сесии.
- **Тествайте цялата среда.** Тествайте приложения, мрежи, облак, AI системи, хардуер и човешкия фактор. Питайте не само „Можем ли да проникнем?“, а и „До кои системи и данни можем да достигнем след първоначалния достъп?“
- **Подгответе незабавна реакция.** Осигурете възможност бързо да прекратявате сесии, да отнемате токени, да деактивирате акаунти и да изолирате устройства. Предвидете и начин за спиране на компрометирани интеграции и автоматизирани процеси.





6. Препоръки

6.3. Съвети за добра кибер хигиена

Добрата кибер хигиена не означава да станете специалист по киберсигурност. Означава приемането и прилагането на няколко навика, които намаляват вероятността от компрометиране.

1. Не използвайте една и съща парола на повече от едно място. Използвайте мениджър на пароли, за да създавате и съхранявате различна силна парола за всеки акаунт.

2. **Включете MFA навсякъде, където е възможно.** За служебни и критични акаунти използвайте устойчиво на фишинг мулти-факторно удостоверяване.

3. Не одобрявайте неочаквана MFA заявка. Ако не сте направили опит за вход, откажете заявката за потвърждение.

4. **Актуализирайте системите.** Особено браузъра, операционната система и интернет-достъпните устройства.

5. Проверявайте спешните съобщения през втори канал. Не променяйте платежни данни и не изпращайте файл само защото съобщението изглежда убедително.

6. **Не изпълнявайте непознати команди.** Ако сайт или непознат човек ви подканва да копирате и изпълните команда в Terminal, PowerShell или Run – не я изпълнявайте.

7. Проверявайте домейна, не само логото. Преди да въведете данните си за вход, погледнете адреса в браузъра – този, който очаквате ли е ? – „mjcrosoft.com”, не е „microsoft.com”.

8. Не инсталирайте непознати инструменти за отдалечен достъп. Проверете кой е отправил искането чрез познат телефонен номер или друг независимо избран канал.

6. Препоръки

9. **Не поставяйте служебна информация в неодобрени AI инструменти.** Това включва пароли, API ключове, клиентски данни, вътрешни документи, код, договори и чувствителни логове.

10. Проверявайте AI-генерирания код. Третирайте го като код от външен източник: преглед, тестване и проверка за сигурност преди внедряване в работната среда.

11. Заключвайте устройството си. Силната парола не помага, ако активната сесия е физически достъпна за друг човек, който има достъп до устройството.

12. **Не работете постоянно с административен акаунт.** Използвайте привилегирован достъп само когато е нужен.

13. Докладвайте подозрителното поведение веднага. Не е нужно предварително да сте доказали, че става дума за атака.

14. **Ако акаунтът ви може да е компрометиран, спрете и потърсете помощ.** Кажете какво сте видели, кога, какво сте натиснали и дали сте въвели парола или сте одобрили MFA.

15. **Пазете и тествайте резервните копия.** Backup, който никога не е възстановяван, не е гарантирано възстановяване.

Целта не е да станете неуязвими — това не е реалистично. Целта е да отстраните слабостите, които улесняват атакуващия: повторно използвани пароли, незакърпени критични уязвимости, ненужни административни права, изпълнение на непознати команди и съхраняване на чувствителни документи в неуправлявани услуги. Последователното прилагане на тези навици ограничава възможностите за успешна атака.





Заключение

Заключение

Киберсигурността през 2026 г. не се определя от една нова технология или една доминираща заплаха. Определя се от скоростта, с която познати слабости могат да се превърнат в реален пробив. Незакърпени системи, компрометирани идентичности, прекомерни права, доверени интеграции, доставчици, социално инженерство и неправилни конфигурации продължават да стоят в основата на голяма част от атаките.

ИИ ускорява процеса. Облакът увеличава броя на идентичностите и връзките. SaaS и веригата за доставки разширяват доверието извън собствената инфраструктура. А атакуващият използва точно тези легитимни механизми — валиден акаунт, браузър, OAuth token, административен инструмент или доставчик — вместо шумно да ги заобикаля.

Това разширява разбирането за защитния периметър. Освен firewall-а той обхваща идентичностите, браузъра, облачните роли, API ключовете, CI/CD процесите, доставчиците и приложенията, които действат от името на потребителя. Защитата трябва да разглежда връзките между тях, защото атакуващият ги използва като последователни стъпки към целта си.

Не е реалистично да обещаем, че всеки инцидент може да бъде предотвратен. Реалистичната цел е друга: компрометирането да бъде по-трудно, действията след него да бъдат по-ограничени, откриването да бъде по-бързо и последствията да бъдат по-малки.

Добрата защита рядко изглежда драматично. Тя изглежда като актуална инвентаризация, навреме приложен актуализация за сигурност, премахнат ненужен достъп, MFA, устойчиво на фишинг, логове, които някой наблюдава, резервно копие, чието възстановяване е проверено, доставчик, чийто достъп може да бъде прекратен, и служител, който знае, че може да докладва проблем, преди да е сигурен какво се случва.

Това е най-важният извод: организациите не трябва да бъдат по-съвършени от атакуващите. Трябва да познават слабостите си и да са подготвени да ги ограничат. Заплахите ще се променят, но организацията, която познава средата си, контролира достъпа и може да реагира без забавяне, отнема на противника две от най-ценните му предимства — времето и свободата да действа незабелязано.





Източници и благодарност

Докладът е изграден върху публични годишни и тематични материали на следните организации и изследователски екипи:

- ENISA — Threat Landscape и тематични анализи на заплахите в ЕС;
- CERT-EU — Cybersecurity Threat Landscape и анализи на злонамерена активност около европейската екосистема;
- Europol — Internet Organised Crime Threat Assessment и материали за онлайн престъпността;
- IBM — Cost of a Data Breach и анализи на икономиката на инцидентите;
- IBM X-Force — Threat Intelligence Index и анализи на експлоатацията на уязвимости;
- Mandiant — M-Trends и анализи на времето до откриване и реакция;
- CrowdStrike — Global Threat Report и анализи на eCrime breakout time;
- Verizon — Data Breach Investigations Report;
- Cisco Talos — годишни и тематични анализи на групи, техники и инциденти;
- Palo Alto Networks Unit 42 — Incident Response и threat research материали;
- Европейска служба за външна дейност — анализи на Foreign Information Manipulation and Interference.

Благодаря на авторите, анализаторите и екипите зад тези материали. Без тяхната работа подобен обзор не би бил възможен. Ако намерите грешка или имате предложение за подобрение или допълнителна информация, най-добрият начин да подобрим следващото издание е да го споделите.

Лиценз: Creative Commons Attribution-NonCommercial-ShareAlike 4.0 International (CC BY-NC-SA 4.0).